



RELATÓRIO INDIVIDUAL PRELIMINAR

TJRJ - Tribunal de Justiça do Estado do Rio de Janeiro

1. Introdução

Este relatório apresenta os resultados preliminares da organização **TJRJ** relativos à Fiscalização TCE-RJ nº 18/2026, realizada pelo TCE-RJ entre fevereiro e junho de 2026 para avaliar o grau de adoção de práticas de governança e gestão de tecnologia da informação e comunicação pelas organizações jurisdicionadas.

O trabalho abrangeu órgãos e entidades de todos os poderes da Administração Pública Estadual e um conjunto de prefeituras municipais.

2. iGovTI 2026

A avaliação das organizações jurisdicionadas baseia-se no método de autoavaliação de controles (*Control Self-Assessment* – CSA), operacionalizado mediante questionário eletrônico. A ferramenta permitiu aos gestores declarar o nível de adoção das práticas de tecnologia da informação avaliadas e encaminhar a documentação probatória correspondente. As evidências anexadas e as justificativas apresentadas foram submetidas à análise de consistência por esta Equipe de Auditoria, servindo de subsídio para eventuais ajustes na pontuação declarada e para a identificação de inconformidades ou achados de auditoria.

O questionário do iGovTI 2026 foi estruturado com o objetivo de diagnosticar aspectos essenciais de governança e gestão de TIC, abrangendo segurança da informação, gestão de riscos, continuidade de negócios, serviços de tecnologia, contratações de TIC, estrutura e força de trabalho, desenvolvimento de soluções, gestão de projetos e temas emergentes, a exemplo do uso de inteligência artificial. Para além do diagnóstico situacional de cada organização, o instrumento serve como referencial metodológico para futuras ações de melhoria de gestão.

O iGovTI 2026 constitui um índice composto, mensurado em uma escala de 0 a 1. A quantificação do índice inicia-se com a conversão das respostas categóricas declaradas em coeficientes numéricos, conforme os critérios de valoração estabelecidos na Tabela 1.

Tabela 1 - Critérios de valoração das respostas qualitativas do questionário iGovTI 2026

Categoria de Resposta Declarada	Coefficiente Numérico
Não adota	0,00
Há decisão formal ou plano aprovado para adotá-lo	0,05
Adota em menor parte	0,15
Adota parcialmente	0,50

Categoria de Resposta Declarada	Coefficiente Numérico
Adota em maior parte ou totalmente	1,00

(Fonte: elaboração própria)

Nas questões que admitem itens de detalhamento, a pontuação da questão principal sofre deduções proporcionais à quantidade de itens não atendidos pela organização. Subsequentemente, os valores são consolidados por meio de agregação ponderada em uma estrutura hierárquica. O índice final é composto por dois blocos principais, conforme detalhado na Figura 1: **Governança de TIC (peso de 47,8%)**, formado por 4 questões de agregação direta; **Gestão de TIC (iGestTI) (peso de 52,2%)**, estruturado em 6 dimensões operacionais que consolidam 20 questões principais ponderadas.

Figura 1 - Composição do iGovTI 2026



(Fonte: elaboração própria)

Com base na pontuação consolidada do iGovTI 2026, a organização é classificada em um de quatro níveis de maturidade, cujos intervalos de pontuação estão definidos na Tabela 2 e representados graficamente na parte inferior da Figura 1.

Tabela 2 - Intervalos de pontuação para enquadramento nos níveis de maturidade

Nível de Maturidade	Intervalo do Índice (iGovTI)
Inexpressivo	$0,00 \leq \text{iGovTI} < 0,15$
Iniciando	$0,15 \leq \text{iGovTI} < 0,40$

Nível de Maturidade	Intervalo do Índice (iGovTI)
Intermediário	$0,40 \leq \text{iGovTI} < 0,70$
Aprimorado	$0,70 \leq \text{iGovTI} \leq 1,00$

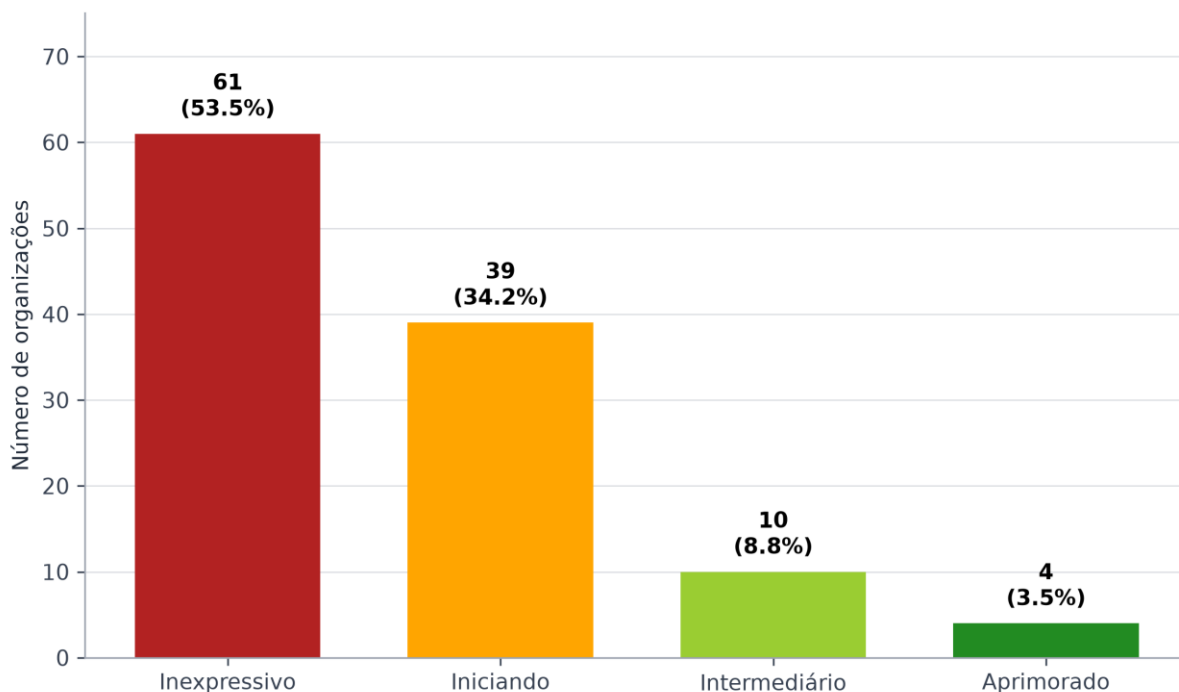
(Fonte: elaboração própria)

2.1. Cenário Geral

A análise consolidada apresentada nesta seção fundamenta-se nos resultados calculados para as 114 organizações que integram o universo amostral da fiscalização. A análise visa contextualizar o resultado individual da organização **TJRJ**, identificar padrões de maturidade, assimetrias entre governança e gestão e capacidades desenvolvidas no conjunto avaliado.

A distribuição por nível de maturidade, apresentada na Figura 2, evidencia concentração nos estágios iniciais. Das 114 organizações, 61 (53,5%) foram classificadas no nível **Inexpressivo** e 39 (34,2%) no nível **Iniciando**. Assim, 100 organizações (87,7%) obtiveram resultado inferior a 0,40. Somente 10 organizações (8,8%) alcançaram o nível **Intermediário** e 4 (3,5%) o nível **Aprimorado**.

Figura 2 - Distribuição das organizações por nível de maturidade do iGovTI 2026



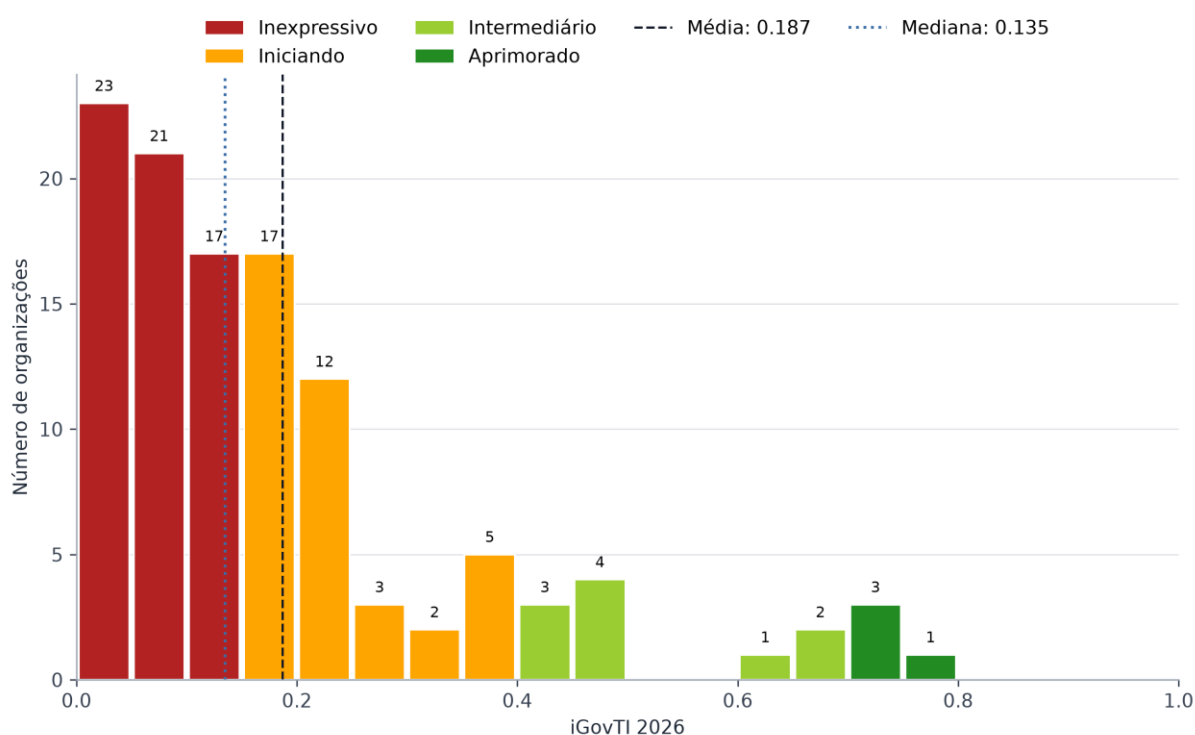
(Fonte: elaboração própria)

O iGovTI apresentou média de 0,187 e mediana de 0,135. O primeiro quartil foi 0,066 e o terceiro quartil, 0,235, o que evidencia a concentração de 50% das organizações avaliadas nesse intervalo, bem como a permanência de pelo menos 75% das entidades

abaixo do nível Intermediário. A divergência positiva entre a média e a mediana, combinada com o valor máximo de 0,777 e com apenas 4 organizações no nível Aprimorado, caracteriza uma distribuição com assimetria à direita (positiva): um grupo reduzido de resultados elevados desloca a média para cima, sem alterar o quadro predominante de baixa maturidade. 5 organizações apresentaram valor igual a zero no índice calculado.

A distribuição contínua da Figura 3 complementa a classificação por faixas e permite observar a concentração dos resultados, os limites de maturidade e a distância entre a mediana e os valores mais elevados.

Figura 3 - Distribuição contínua dos resultados do iGovTI 2026



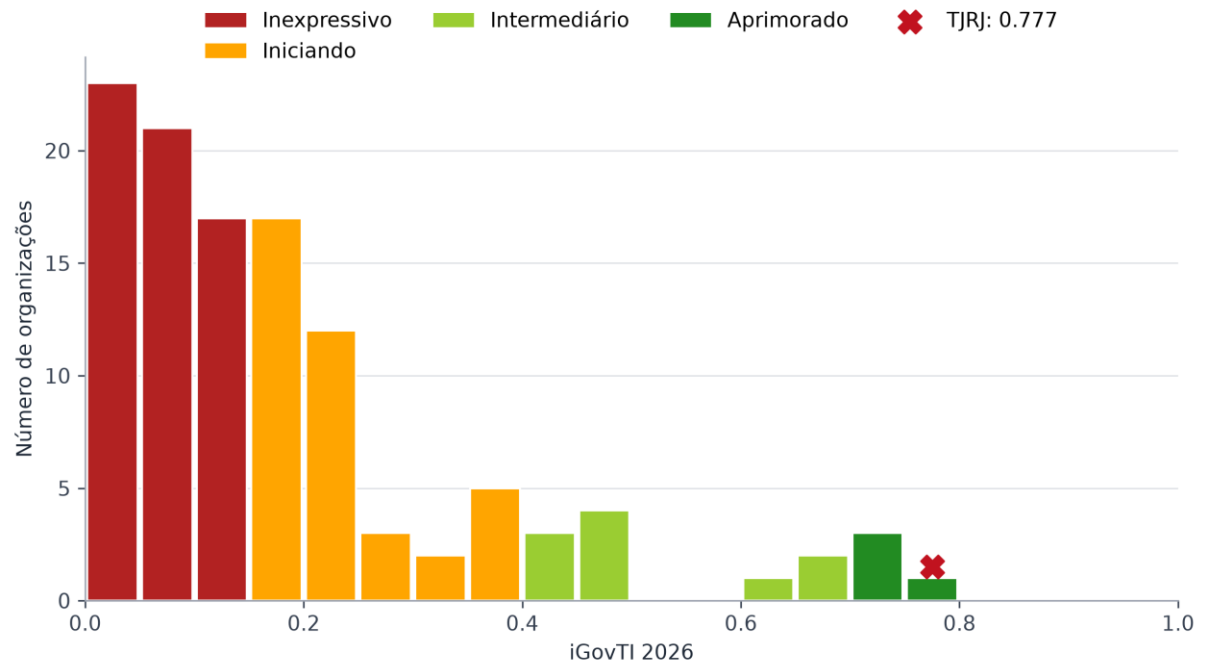
(Fonte: elaboração própria)

A posição específica da organização **TJRJ** nessa distribuição pode ser observada na Figura 4. Diferenças marginais de pontuação entre organizações adjacentes no ranking devem ser interpretadas com cautela analítica, visto que o modelo matemático de composição do índice não pressupõe estimativa de erro amostral e que os resultados estão sujeitos à qualidade e à fidedignidade declaratória do jurisdicionado.

2.2. Cenário atual - TJRJ

Apresentado o panorama geral do universo fiscalizado, esta subseção detalha o desempenho específico da organização jurisdicionada. A organização **TJRJ** obteve o **valor 0,7767 para o iGovTI 2026**, correspondente ao nível **Aprimorado** de maturidade.

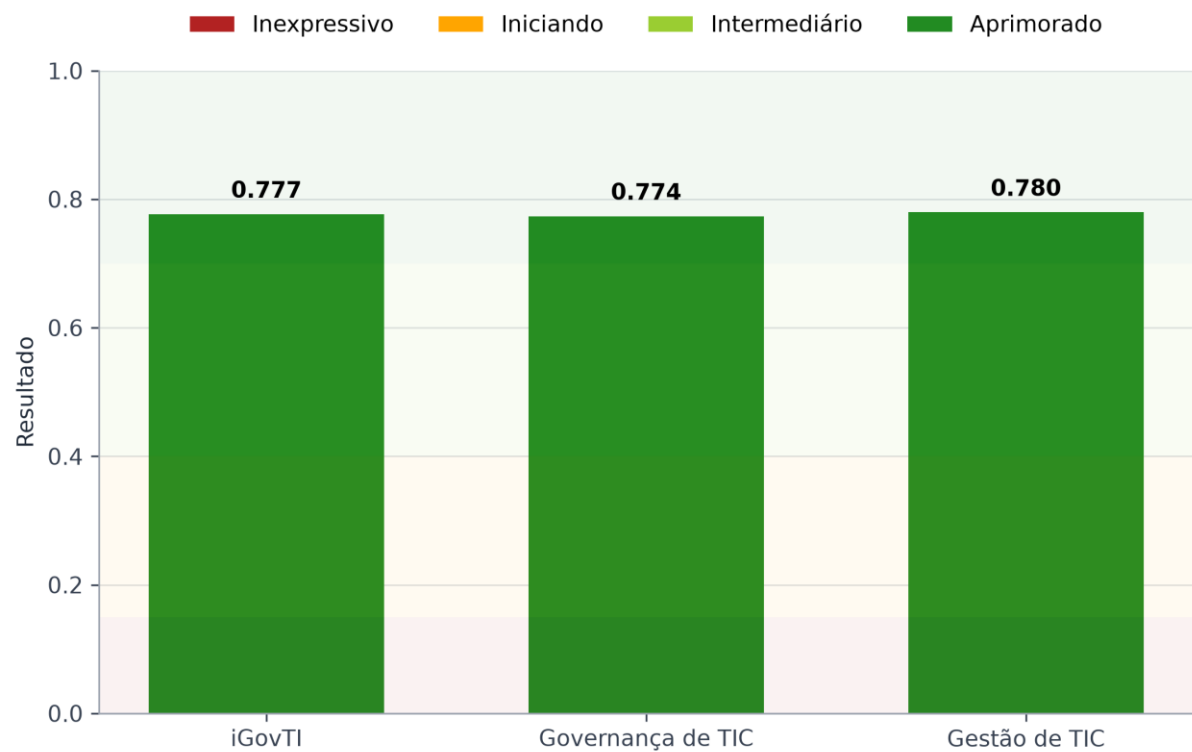
Figura 4 - Distribuição dos resultados do iGovTI 2026 e posição da organização TJRJ



(Fonte: elaboração própria)

A Figura 5 apresenta a composição do resultado da organização **TJRJ** entre governança e gestão de TIC.

Figura 5 - Resultado da organização TJRJ por componentes do iGovTI 2026



(Fonte: elaboração própria)

Tabela 3 - Resultado sintético do iGovTI 2026 da organização TJRJ

Componente	Peso no iGovTI 2026	Valor
Governança de TIC	0,4777	0,7735
Gestão de TIC	0,5223	0,7795
iGovTI 2026	1,0000	0,7767

(Fonte: elaboração própria)

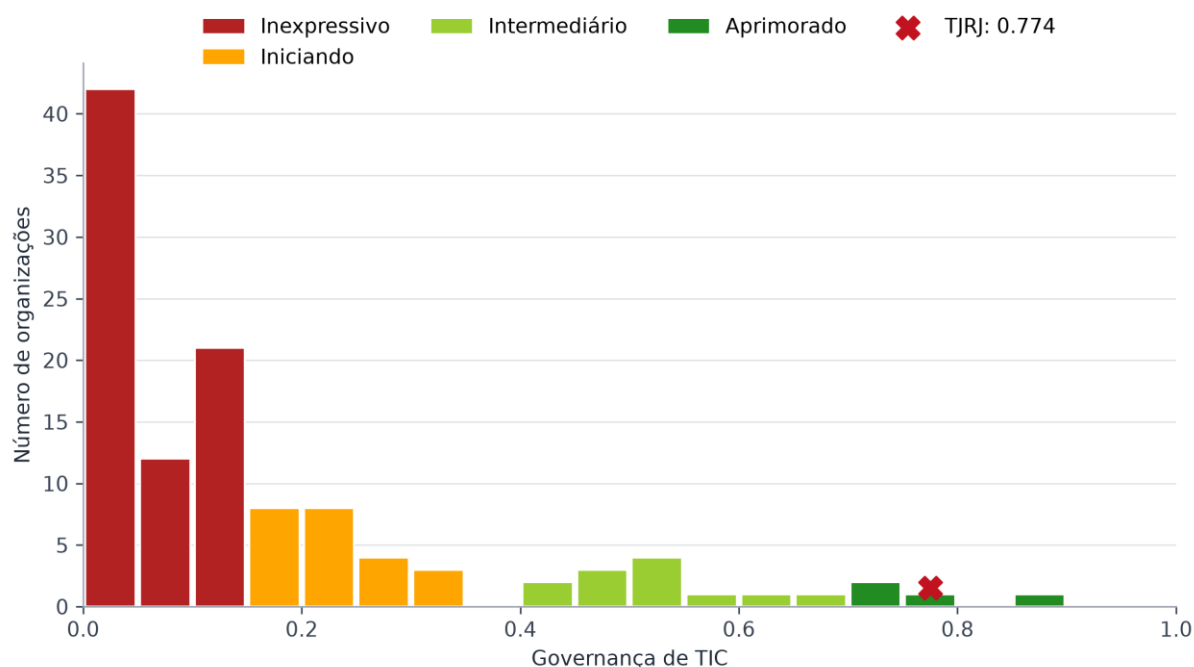
2.2.1. Governança de TIC

A governança de TIC avalia a capacidade da alta administração de orientar, dirigir, monitorar e controlar o uso da tecnologia da informação, de modo alinhado aos objetivos institucionais, aos riscos relevantes e às necessidades das áreas finalísticas e administrativas.

No iGovTI 2026, a dimensão de governança consolida práticas relacionadas ao modelo de gestão de TIC, à atuação de comitês ou instâncias equivalentes, no monitoramento do desempenho, à participação da alta administração e ao alinhamento entre decisões de TIC, estratégia organizacional, orçamento, riscos e valor público.

A organização **TJRJ** obteve o **valor 0,7735 no componente Governança de TIC**.

Figura 6 - Resultado do componente Governança de TIC da organização TJRJ



(Fonte: elaboração própria)

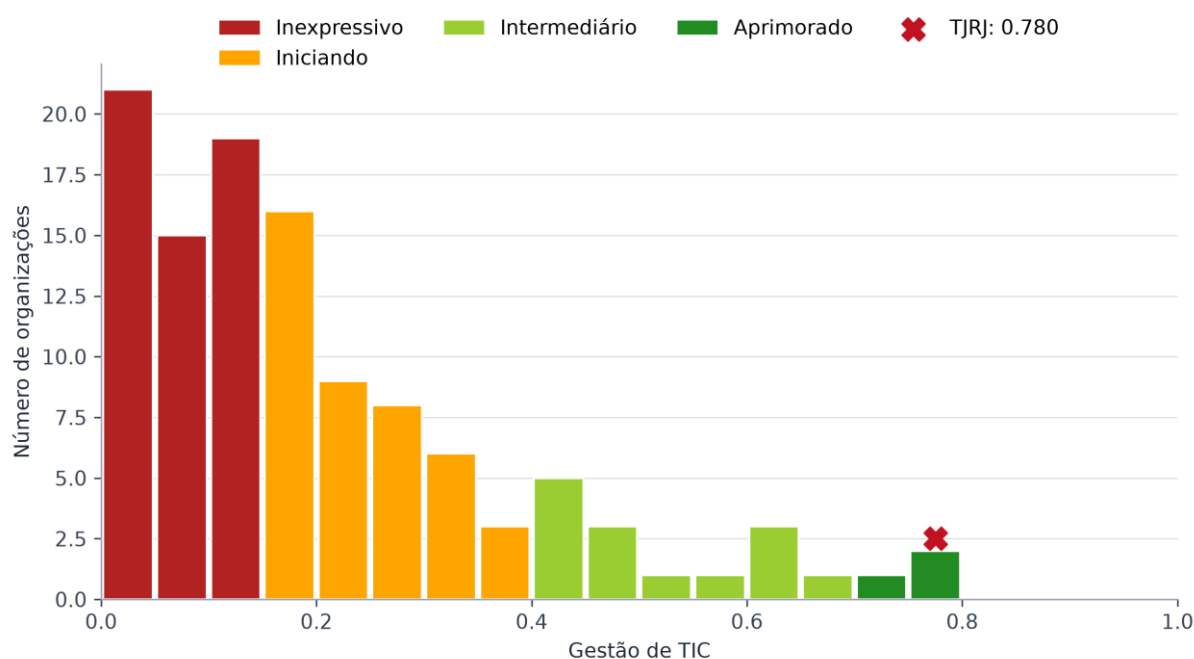
2.2.2. Gestão de TIC

A gestão de TIC avalia a capacidade da organização de planejar, executar, monitorar e aperfeiçoar processos, serviços, controles, recursos e contratações de tecnologia da informação, de forma compatível com suas necessidades institucionais.

No iGovTI 2026, o componente **Gestão de TIC (iGestTI)** consolida seis dimensões operacionais: planejamento de TIC, gestão de serviços de TIC, gestão de riscos de TI e segurança da informação, estrutura de segurança da informação, processos de segurança da informação e gestão de soluções de TIC.

A organização **TJRJ** obteve o **valor 0,7795 no componente Gestão de TIC**.

Figura 7 - Resultado do componente Gestão de TIC da organização TJRJ

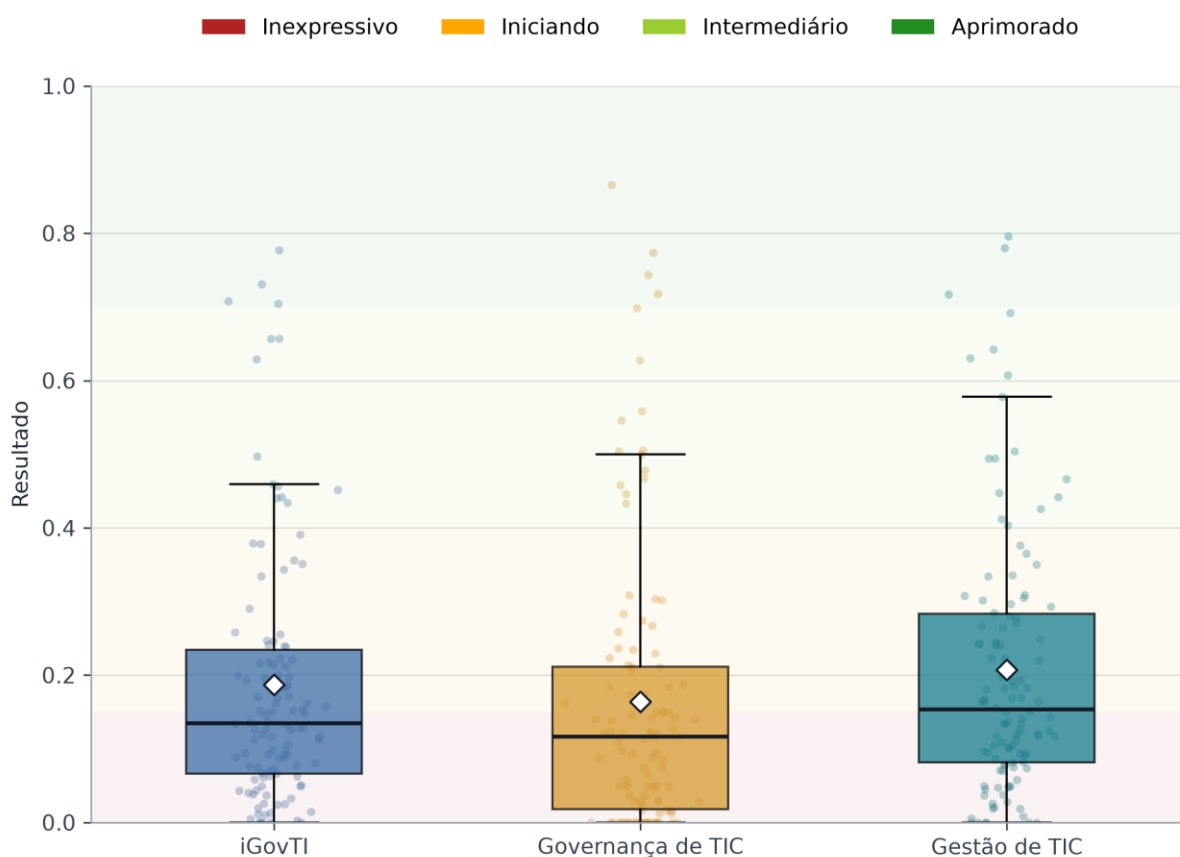


Indicador	Média	1º quartil	Mediana	3º quartil	Organizações com valor >= 0,40	Valor TJRJ
iGovTI	0,187	0,066	0,135	0,235	14 (12,3%)	0,7767
Governança de TIC	0,164	0,018	0,117	0,211	16 (14,0%)	0,7735
Gestão de TIC	0,208	0,082	0,153	0,283	17 (14,9%)	0,7795

(Fonte: elaboração própria)

A Figura 8 permite comparar a dispersão dos três indicadores. O resultado em Gestão de TIC superou o de Governança de TIC em 76 organizações (66,7%); o movimento inverso ocorreu em 33 (28,9%); e houve igualdade em 5 (4,4%). O padrão indica que, para a maior parte das organizações, as capacidades operacionais de gestão se situaram em patamar superior ao dos mecanismos de direção, monitoramento e controle exercidos pela alta administração. Essa diferença, contudo, não elimina a baixa maturidade da gestão: 97 organizações (85,1%) também obtiveram resultado em Gestão de TIC inferior a 0,40.

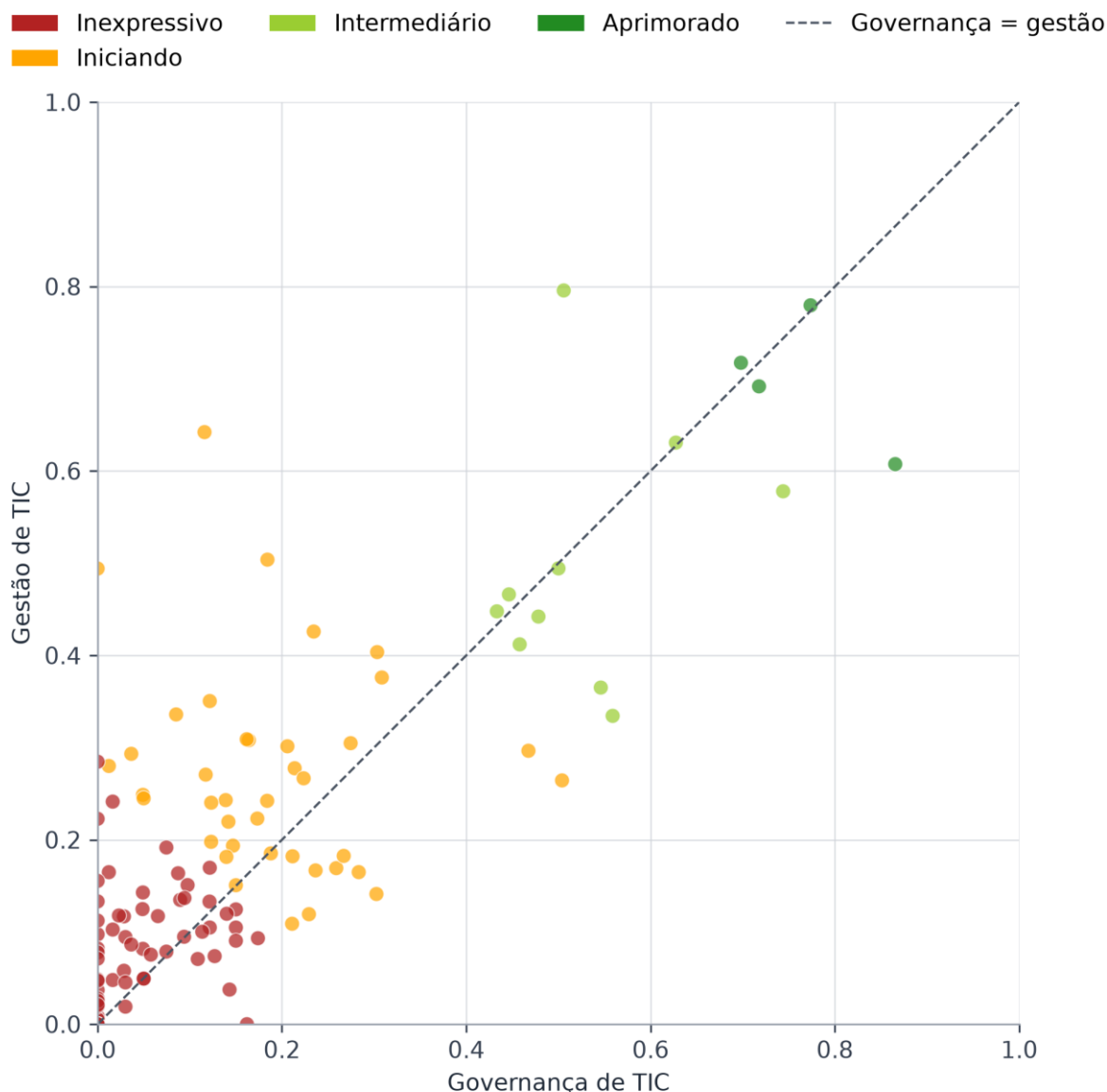
Figura 8 - Distribuição do iGovTI 2026 e dos componentes Governança de TIC e Gestão de TIC



(Fonte: elaboração própria)

A Figura 9 mostra a posição simultânea das organizações nos dois componentes. Pontos abaixo da diagonal representam resultado de gestão superior ao de governança; pontos acima da diagonal representam a situação inversa.

Figura 9 - Relação entre os resultados de governança e gestão de TIC



(Fonte: elaboração própria)

No caso da organização **TJRJ**, os componentes de Governança de TIC e Gestão de TIC situam-se em patamar **Aprimorado**. Eventual diferença entre os componentes deve ser interpretada como variação relativa de perfil, e não como indicativo, por si só, de fragilidade estrutural. A leitura deve considerar os achados específicos, quando existentes, e as oportunidades pontuais de aperfeiçoamento identificadas nas dimensões avaliadas.

2.4. Dimensões da gestão de TIC

A decomposição da Gestão de TIC revela diferenças relevantes entre as seis dimensões avaliadas. Conforme a Tabela 5, **Planejamento de TIC** apresentou a maior média (0,293) e a maior mediana (0,157). A dimensão com maior média também figurou

como a de maior resultado em 50 organizações (43,9%), considerados os empates. Esse padrão indica que algumas capacidades se encontram mais disseminadas do que outras no conjunto fiscalizado.

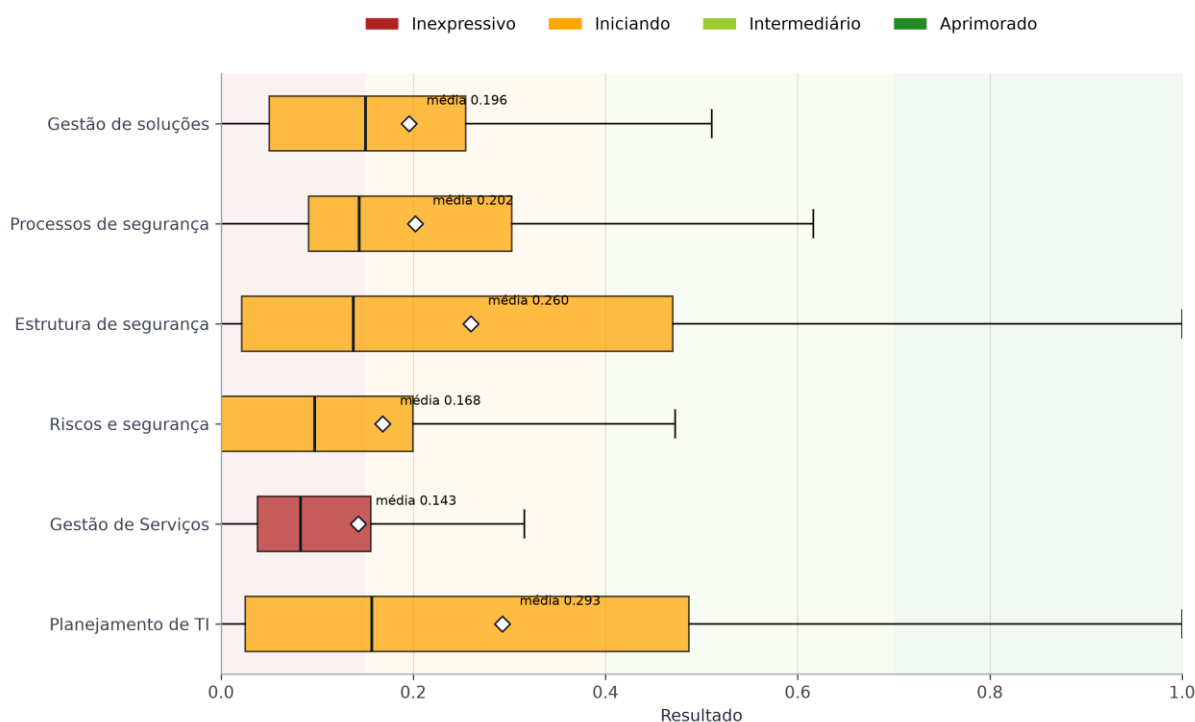
Tabela 5 - Estatísticas descritivas das dimensões de Gestão de TIC

Dimensão	Média	Mediana	Resultados iguais a zero	Organizações com valor inferior a 0,40	Valor TJRJ
Planejamento de TIC	0,293	0,157	21 (18,4%)	80 (70,2%)	0,7019
Gestão de Serviços de TIC	0,143	0,083	20 (17,5%)	102 (89,5%)	0,7092
Gestão de Riscos de TI e Segurança da Informação	0,168	0,097	32 (28,1%)	97 (85,1%)	0,8506
Estrutura de Segurança da Informação	0,260	0,137	25 (21,9%)	83 (72,8%)	1,0000
Processos de Segurança da Informação	0,202	0,144	10 (8,8%)	95 (83,3%)	0,5329
Gestão de Soluções de TIC	0,196	0,150	26 (22,8%)	101 (88,6%)	0,9279

(Fonte: elaboração própria)

A distribuição completa das seis dimensões é apresentada na Figura 10, incluindo medianas, intervalos interquartis e médias.

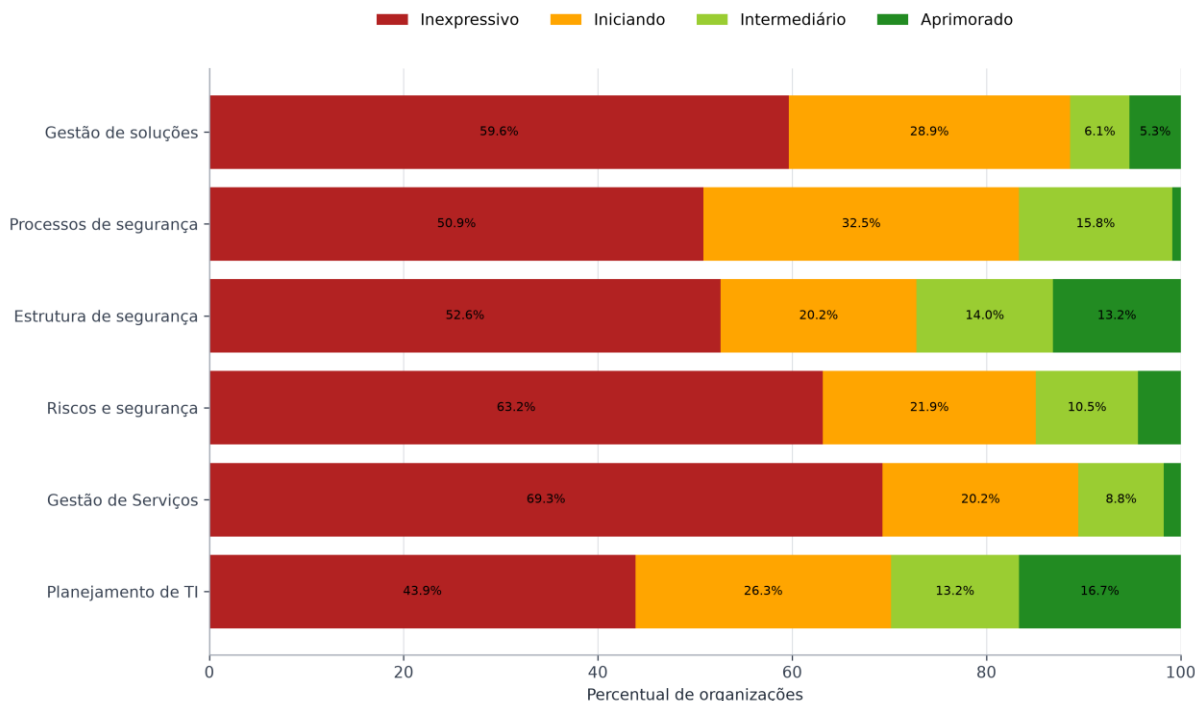
Figura 10 - Distribuição dos resultados das seis dimensões de Gestão de TIC



(Fonte: elaboração própria)

A Figura 11 explicita a composição de cada dimensão por nível de maturidade e permite verificar em quais capacidades se concentram as organizações nos estágios iniciais.

Figura 11 - Distribuição dos níveis de maturidade das organizações nas dimensões de Gestão de TIC



(Fonte: elaboração própria)

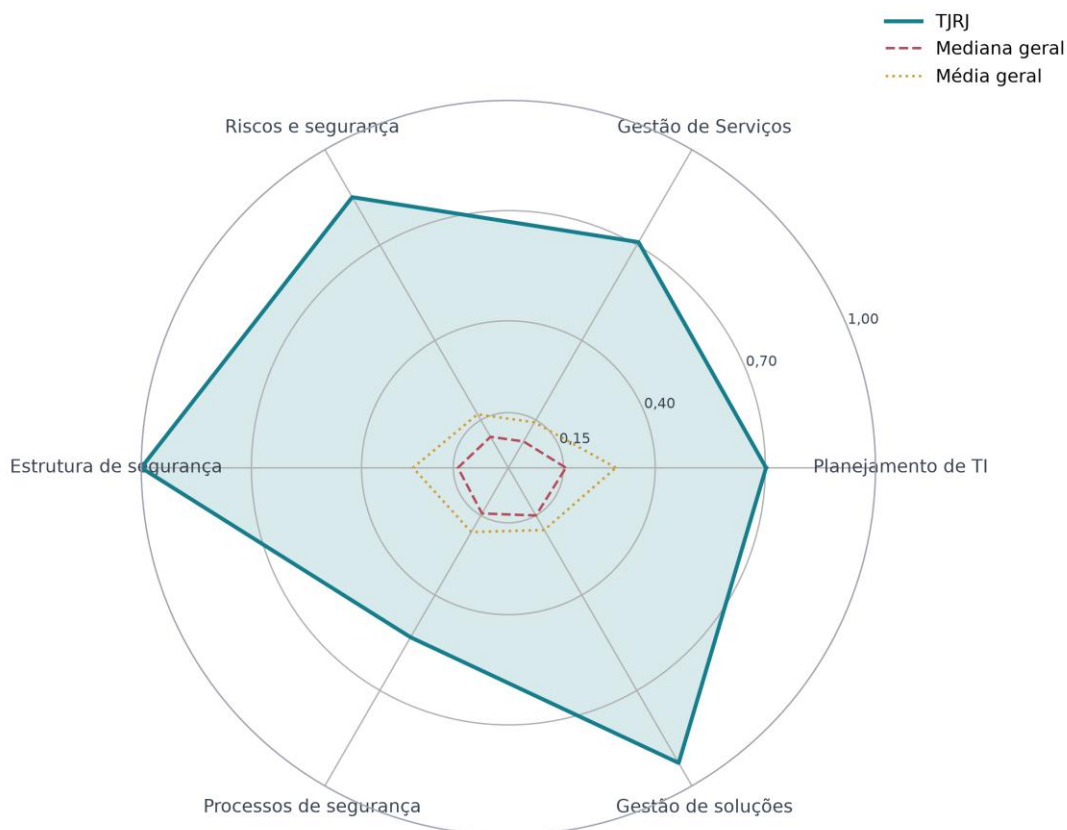
As menores médias foram observadas em **Gestão de serviços de TIC** (0,143) e **Riscos de TI e de segurança da informação** (0,168). A primeira registrou valor inferior a 0,40 em 102 organizações (89,5%) e apareceu entre as dimensões de menor resultado de 37 organizações (32,5%), considerados os empates. Para a segunda, esses quantitativos foram, respectivamente, 97 (85,1%) e 39 (34,2%). O quadro indica que a formalização do planejamento, quando existente, frequentemente não é acompanhada, na mesma intensidade, pelas demais capacidades operacionais e de segurança.

A dimensão Estrutura de Segurança da Informação apresentou média de 0,260 e mediana de 0,137. Essa diferença, associada à ampla dispersão observada na Figura 10, evidencia heterogeneidade: um grupo de organizações possui estruturas de segurança mais consolidadas, enquanto parcela expressiva permanece próxima dos níveis inferiores. A dimensão Processos de Segurança da Informação mostrou mediana superior à de Estrutura de Segurança da Informação, mas 83,3% das organizações ainda permaneceram abaixo de 0,40, o que recomenda examinar separadamente a existência da estrutura formal e a execução contínua dos processos de segurança.

2.5. Leitura integrada do resultado individual

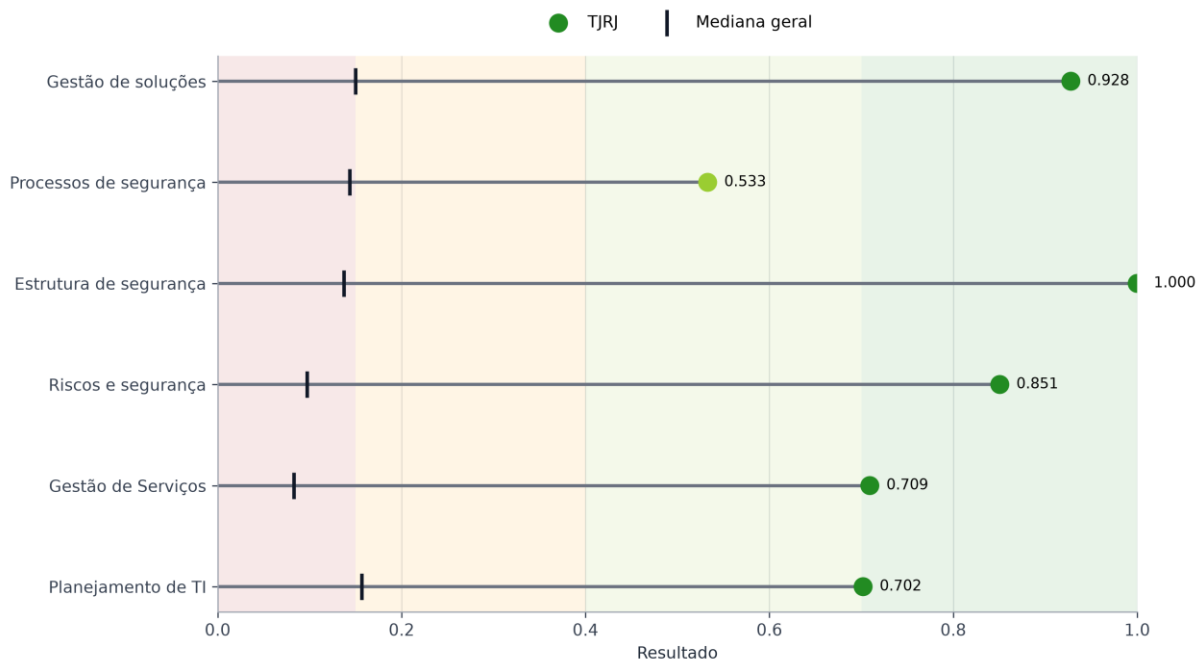
A Figura 12 apresenta o perfil da organização **TJRJ** nas seis dimensões de gestão e o compara com as medianas observadas nas 114 organizações. A comparação linear da Figura 13 permite identificar com maior precisão a distância entre o resultado individual e a mediana geral em cada dimensão.

Figura 12 - Perfil da organização nas dimensões de Gestão de TIC em comparação com os demais



(Fonte: elaboração própria)

Figura 13 - Comparação do resultado individual e da mediana nas dimensões de Gestão de TIC

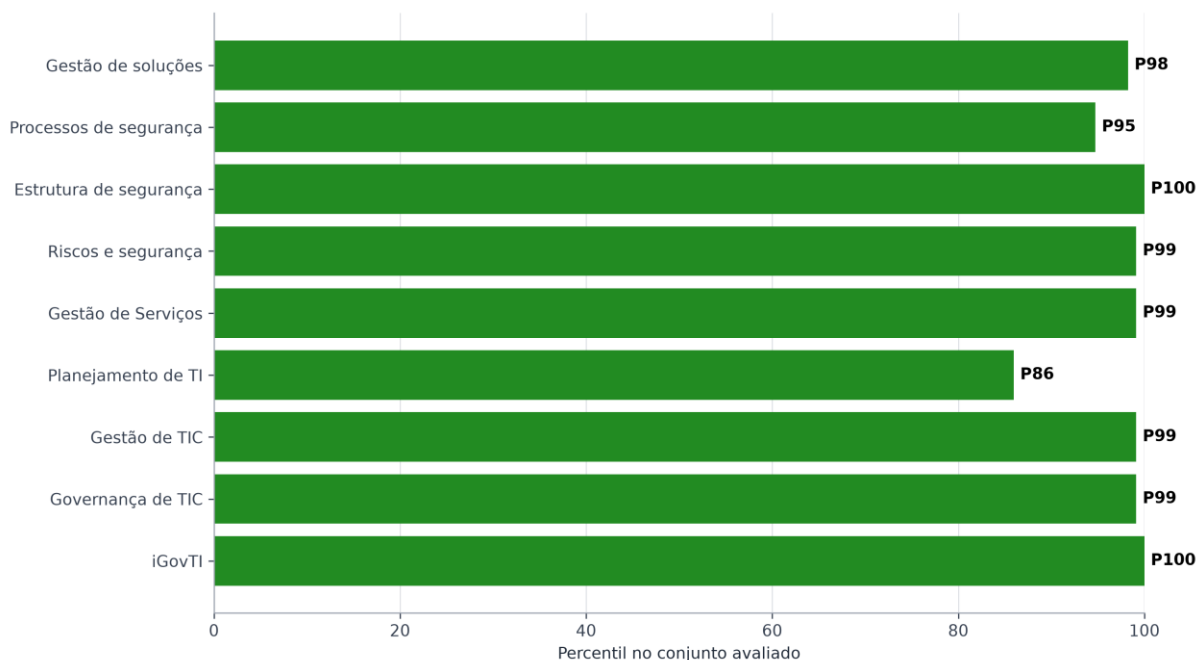


(Fonte: elaboração própria)

A Figura 14 compara a posição da organização **TJRJ** com as demais organizações avaliadas em cada indicador. A letra “P” indica a posição relativa (percentil) no conjunto: **P50** representa posição próxima ao centro da distribuição; **P90** indica que a organização obteve resultado igual ou superior ao de aproximadamente 90% das organizações avaliadas; e **P20** indica que apenas cerca de 20% das organizações tiveram resultado igual ou inferior. Assim, quanto maior o valor de “P”, melhor é a posição relativa da organização naquele indicador.

Essa comparação deve ser interpretada com cautela. A posição relativa não substitui o valor do índice, o nível de maturidade nem a análise de conformidade realizada nos achados de auditoria. Ela serve apenas para indicar se o resultado da organização ficou relativamente abaixo, próximo ou acima do conjunto avaliado.

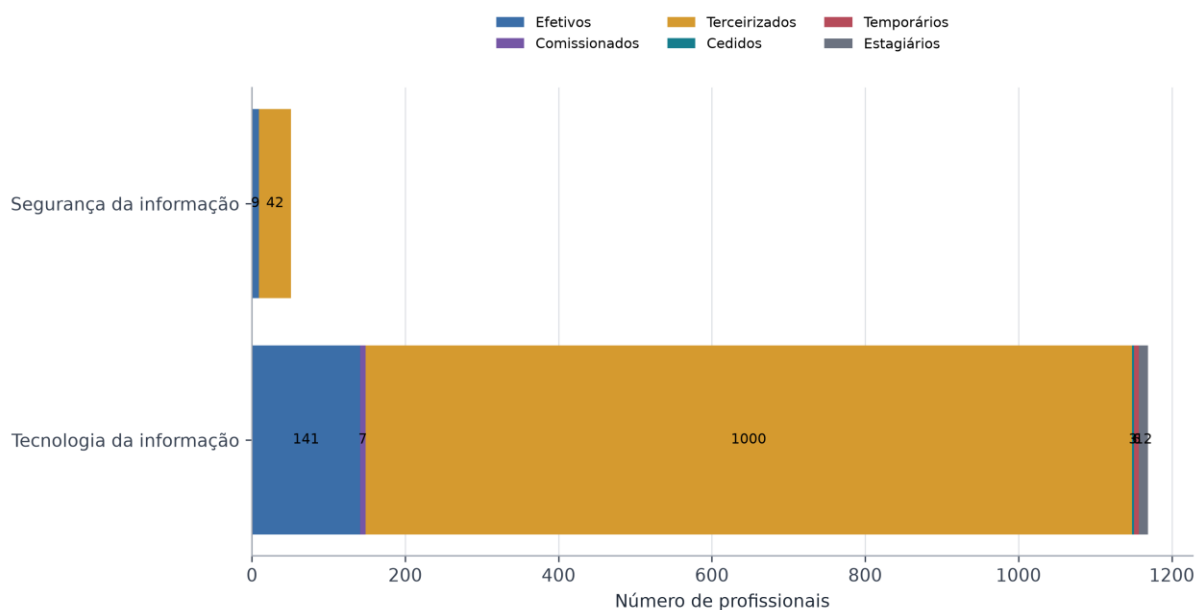
Figura 14 - Comparação da posição relativa da organização TJRJ nos indicadores avaliados



(Fonte: elaboração própria)

A composição declarada da força de trabalho de TIC e de segurança da informação é apresentada na Figura 15. Os quantitativos não compõem o índice e não medem, isoladamente, suficiência de pessoal; sua avaliação depende do porte, da complexidade, da terceirização, dos serviços mantidos e dos riscos da organização.

Figura 15 - Composição declarada da força de trabalho de TIC e segurança da informação



(Fonte: elaboração própria)

A priorização de melhorias não deve buscar apenas a elevação numérica do índice. Recomenda-se concentrar esforços nas capacidades com menor resultado que, simultaneamente, estejam associadas a riscos relevantes, serviços críticos, obrigações normativas e necessidades institucionais da organização **TJRJ**.

SIGILOSO

3. Resultados da Auditoria

No âmbito desta fiscalização, foram definidas questões de auditoria para orientar a avaliação da governança e da gestão de TIC. Para fins deste relatório individual preliminar, os possíveis achados decorrem da verificação das Questões 1 a 6.

Tabela 7 - Questões de auditoria com avaliação individual preliminar

Questão	Tema	Síntese do objeto avaliado
Q1	Estrutura de TIC	Existência formal, atribuições e posicionamento organizacional da área, unidade, setor ou função responsável pela TIC.
Q2	Governança e comitê de TIC	Modelo de governança e gestão de TIC, objetivos, indicadores, metas e atuação do comitê ou instância equivalente.
Q3	Planejamento de TIC	Processo de planejamento, plano de TIC vigente, aprovação, alinhamento institucional, integração orçamentária e acompanhamento.
Q4	Capacidade institucional de TIC e segurança da informação	Força de trabalho, perfis, competências, funções, vínculos e capacidade interna para sustentar a TIC e a segurança da informação.
Q5	Gestão de serviços de TIC	Catálogo de serviços, níveis mínimos de serviço, inventário de ativos, gestão de configuração e tratamento de incidentes.
Q6	Contratações de TIC	Fluxo de contratação, papéis, modelos orientativos, aprovação técnica, alinhamento ao planejamento e equipe de planejamento.

(Fonte: elaboração própria)

Não foram identificados achados individuais preliminares relacionados às Questões 1 e 2 para esta organização. Por essa razão, os achados apresentados a seguir preservam a numeração vinculada às questões de auditoria que lhes deram origem.

Os achados de auditoria decorrem da avaliação preliminar das respostas da organização **TJRJ** ao questionário iGovTI 2026 e da correspondente análise de consistência documental realizada por esta Equipe de Auditoria. O trabalho consistiu no confronto sistemático entre as práticas de governança e gestão autodeclaradas pela organização e as evidências comprobatórias efetivamente encaminhadas, à luz da legislação aplicável e de padrões técnicos de referência internacional.

O presente relatório individual adota uma estrutura analítica de apresentação voltada a conferir clareza, rastreabilidade e utilidade diagnóstica às constatações. Desse modo, cada achado de auditoria está estruturado a partir dos seguintes elementos fundamentais:

- **Critérios:** as referências normativas, legais, regulamentares ou de boas práticas de gestão (como os objetivos do COBIT 2019 e normas da série ABNT NBR ISO/IEC) que estabelecem o padrão esperado de conformidade;

- **Evidências:** a relação das informações e dos documentos anexados pela organização que serviram de suporte factual para as constatações;
- **Situação Encontrada:** a descrição detalhada da realidade operacional e documental identificada no jurisdicionado, destacando-se as fragilidades e lacunas específicas em relação aos critérios adotados;
- **Conclusão da Equipe de Auditoria:** a análise técnica e o juízo profissional formulado a partir da correlação entre a situação factual e as regras de controle estabelecidas no mapa de verificação;
- **Propostas de Encaminhamento:** as recomendações preliminares propostas com o intuito de orientar a organização na correção de fragilidades e no aprimoramento de suas capacidades de governança e gestão de TIC.

Cumprе ressaltar o caráter preliminar das constatações ora apresentadas. A disponibilização deste relatório visa subsidiar a fase de comentários do gestor, permitindo à organização apresentar esclarecimentos adicionais, correções de fato ou novas informações que possam orientar a manifestação final desta Corte de Contas.

Achado 3 – Planejamento de TIC insuficiente para orientar a gestão, o orçamento e as contratações de TIC

Crítérios

- COBIT 2019, APO02.05 - Definir o plano e o roteiro estratégico: estabelecer plano e roteiro de TIC que traduzam a estratégia em iniciativas, prioridades, recursos, dependências, prazos e benefícios esperados;
- COBIT 2019, APO06.03 - Criar e manter orçamentos: elaborar e manter orçamento de TIC alinhado ao portfólio, ao planejamento e às prioridades aprovadas;
- Acórdão 1.411/2014-TCU-Plenário, item 9.1.6 e subitens 9.1.6.1 a 9.1.6.4: necessidade de instituir formalmente plano diretor de TI, contemplando desdobramento de diretrizes estratégicas, vinculação das ações de TI a indicadores e metas de negócio, vinculação das ações de TI a indicadores e metas de serviços ao cidadão e vinculação das ações priorizadas ao orçamento de TI;
- Acórdão TCE-RJ 44.490/2024-PLEN, item II.3 e subitens II.3.1 a II.3.5: necessidade de estabelecer processo estruturado, com participação de representantes das principais secretarias, para elaborar, manter e revisar periodicamente o PDTI, contemplando objetivos, indicadores e metas de TI alinhados aos objetivos de negócio, riscos que possam impactar objetivos e metas, projetos, aquisições e ações necessárias, alocação de recursos e ações de divulgação e monitoramento do PDTI após aprovação pela autoridade máxima.

Evidências

- **E1:** Resposta negativa ao detalhamento b) do item 2101 do Questionário, para verificar se a organização estabeleceu critérios para orientar a seleção e a priorização das iniciativas de TI (projetos e ações) e os mantém atualizados;
- **E2:** Resposta negativa ao detalhamento c) do item 2101 do Questionário, para verificar se as análises de benefícios, de custos e de riscos subsidiam as decisões relacionadas à seleção e à priorização das iniciativas de TI (projetos e ações);
- **E3:** Resposta negativa ao detalhamento c) do item 2102 do Questionário, para verificar se o plano de TI fundamenta a proposta orçamentária da área de TI e o plano de contratações.

Situação encontrada

O planejamento de TIC é instrumento fundamental para traduzir diretrizes institucionais em iniciativas, prioridades, recursos, prazos, responsáveis e resultados

esperados. Sob a perspectiva de governança pública, a administração deve executar processo formal de planejamento, contar com plano de TIC formalmente aprovado, assegurar participação das áreas finalísticas, alinhar o plano ao planejamento institucional, integrá-lo ao orçamento e às contratações e acompanhá-lo periodicamente.

Os critérios de boas práticas indicam que o planejamento de TIC deve estabelecer plano e roteiro estratégico, manter orçamento alinhado ao portfólio e às prioridades aprovadas, vincular ações de TIC a indicadores, metas e orçamento de TI, e contemplar processo estruturado de elaboração, manutenção e revisão periódica do PDTI¹.

Com base na análise das respostas aos itens 2101, 2102, 2802 e 2804 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrado atendimento integral a esses requisitos de planejamento. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Processo formal de planejamento:** a fragilidade no processo de elaboração não demonstra aderência aos critérios do COBIT 2019 (APO02.05), do Acórdão 1.411/2014-TCU-Plenário e do Acórdão TCE-RJ 44.490/2024-PLEN, o que pode favorecer atuação reativa e sem critérios objetivos de seleção e priorização de iniciativas.
- **Integração orçamentária e operacional:** a ausência de vínculo demonstrado com orçamento e contratações de TIC não demonstra aderência ao COBIT 2019 (APO06.03), ao Acórdão 1.411/2014-TCU-Plenário e ao Acórdão TCE-RJ 44.490/2024-PLEN, favorecendo aquisições reativas, não priorizadas e desalinhadas das metas de TIC.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Processo formal de planejamento de TIC

O processo formal de planejamento de TIC deve definir etapas, responsáveis, participação das áreas demandantes e critérios mínimos de priorização. Esse processo é necessário para que o planejamento deixe de ser uma atividade eventual e passe a constituir rotina institucional de identificação, seleção, priorização e acompanhamento de demandas de tecnologia.

O COBIT 2019, no objetivo APO02.05, orienta a definição de plano e roteiro estratégico de TIC que traduzam a estratégia em iniciativas, prioridades, recursos, dependências, prazos e benefícios esperados. O Acórdão TCE-RJ 44.490/2024-PLEN, item II.3, também aponta a necessidade de processo estruturado, com participação de

¹ Os critérios de planejamento de TIC convergem para a necessidade de plano formal, aprovado, vigente, alinhado à estratégia institucional, integrado ao orçamento e às contratações e acompanhado periodicamente.

representantes das principais secretarias, para elaborar, manter e revisar periodicamente o PDTI.

O processo deve ser demonstrado por norma, procedimento, guia ou instrumento equivalente que discipline a elaboração, revisão, aprovação e acompanhamento do planejamento de TIC.

Da análise das respostas ao item 2101 e da documentação apresentada, verificou-se que o processo formal de planejamento de TIC não se mostrou suficientemente estruturado quanto a etapas, responsáveis, participação das áreas demandantes e critérios de priorização, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem b) do item 2101, não houve declaração afirmativa quanto à prática avaliada: estabeleceu critérios para orientar a seleção e a priorização das iniciativas de TI (projetos e ações) e os mantém atualizados (E1);
- No subitem c) do item 2101, não houve declaração afirmativa quanto à prática avaliada: as análises de benefícios, de custos e de riscos subsidiam as decisões relacionadas à seleção e à priorização das iniciativas de TI (projetos e ações) (E2).

A inexistência ou fragilidade desse processo expõe a organização a uma atuação reativa e à alocação de recursos em iniciativas de tecnologia sem critérios claros de priorização.

Vínculo com orçamento e contratações de TIC

O planejamento de TIC deve ser vinculado com a proposta orçamentária, o plano de contratações e as contratações executadas. Essa integração é necessária para que as iniciativas priorizadas tenham suporte financeiro, sejam convertidas em contratações coerentes e possam ser acompanhadas ao longo da execução.

O COBIT 2019, APO06.03, orienta a criação e manutenção de orçamento de TIC alinhado ao portfólio, ao planejamento e às prioridades aprovadas. O Acórdão 1.411/2014-TCU-Plenário também exige vinculação das ações priorizadas ao orçamento de TI, e o Acórdão TCE-RJ 44.490/2024-PLEN prevê projetos, aquisições, ações necessárias e alocação de recursos no PDTI.

Da análise das respostas aos itens 2102, 2802 e 2804 e da documentação apresentada, verificou-se que o vínculo entre o plano de TIC, a proposta orçamentária, o plano de contratações ou as contratações de TIC executadas não se mostrou suficientemente demonstrado, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 2102, não houve declaração afirmativa quanto à prática avaliada: o plano de TI fundamenta a proposta orçamentária da área de TI e o plano de contratações (E3).

A falta de integração demonstrada entre o planejamento de tecnologia, as previsões orçamentárias, o plano de contratações e as contratações executadas eleva o risco de aquisições isoladas, reativas ou insuficientemente priorizadas sob a perspectiva técnica.

Conclusão

As fragilidades identificadas no planejamento de TIC reduzem a segurança de que a organização disponha, conforme aplicável ao caso concreto, de processo e instrumento suficientes para direcionar iniciativas, priorizar recursos, alinhar projetos às necessidades institucionais e integrar orçamento e contratações à estratégia de tecnologia.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à adequação dos aspectos de planejamento de TIC efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que institua processo formal de planejamento de TIC, compatível com o porte e a maturidade da organização, atentando-se, minimamente, em definir etapas, responsáveis, participação das áreas demandantes e critérios de priorização das necessidades e iniciativas de TIC;
- **Comunicação com Recomendação** para que integre o plano de TIC à proposta orçamentária, ao plano de contratações e às contratações de TIC, atentando-se, minimamente, em priorizar as demandas conforme sua relevância, seus riscos e a capacidade de execução da organização.

Achado 4 – Capacidade institucional insuficiente para sustentar a gestão de TIC e segurança da informação

Critérios

- COBIT 2019, APO01.05 - Estabelecer papéis e responsabilidades: definir, comunicar e manter papéis e responsabilidades relacionados à governança e gestão de TIC;
- COBIT 2019, APO07.01 - Adquirir e manter pessoal adequado e apropriado: assegurar quantidade e perfil de profissionais compatíveis com as necessidades de TIC;
- COBIT 2019, APO07.02 - Identificar pessoal-chave de TI: identificar funções e pessoas críticas para reduzir dependência individual, perda de conhecimento e descontinuidade;
- COBIT 2019, APO07.06 - Gerenciar pessoal contratado: controlar o uso de pessoal terceirizado ou externo, preservando responsabilização, supervisão e retenção de conhecimento;
- COBIT 2019, APO10.04 - Gerenciar risco de fornecedores: identificar e tratar riscos decorrentes de fornecedores, contratos e dependências externas relevantes para TIC;
- COBIT 2019, DSS01.02 - Gerenciar serviços de TI terceirizados: assegurar que serviços terceirizados sejam supervisionados, medidos e integrados aos controles da organização;

Evidências

- **E1:** A organização declarou “Sim” no subitem b) do item 2708, mas a evidência encaminhada foi considerada insuficiente para comprovar que possui em sua estrutura cargos ou funções formalmente atribuídas à área de tecnologia da informação;
 - Justificativa da avaliação: A avaliação realizada conclui pela insuficiência da evidência apresentada. O material consiste exclusivamente em captura de tela de interface de compartilhamento de arquivos, carecendo de qualquer organograma, ato de designação ou normativo interno que vincule formalmente funções à área de tecnologia da informação. A evidência é ineficaz para demonstrar a estrutura organizacional pretendida. A lacuna principal é a inexistência de documento oficial que formalize tais atribuições;
- **E2:** A organização declarou “Sim” no subitem d) do item 2708, mas a evidência encaminhada foi considerada insuficiente para comprovar que possui em sua

estrutura cargos ou funções formalmente atribuídas à área de segurança da informação;

- Justificativa da avaliação: A avaliação realizada conclui pela insuficiência da evidência. O arquivo enviado não contém elementos comprobatórios como organogramas, normas ou atos de designação que formalizem atribuições para a área de segurança da informação, limitando-se a uma imagem de interface de sistema. A evidência não permite confirmar a existência da estrutura organizacional necessária. A lacuna consiste na falta de documentação oficial que detalhe a função ou cargo em segurança da informação;
- **E3:** Predomínio de profissionais terceirizados de TI em relação ao quantitativo de profissionais internos, conforme informado em resposta ao item 0105.

Situação encontrada

A capacidade institucional de TIC e segurança da informação pressupõe dispor de recursos humanos, competências, perfis profissionais, funções e vínculos contratuais adequados para planejar, coordenar, gerir, proteger, contratar, fiscalizar e sustentar o ambiente tecnológico. Sob a perspectiva de controle e governança, a estruturação formal de uma unidade de tecnologia deve ser acompanhada de capacidade técnica compatível para exercer a supervisão de suas atribuições estratégicas.

Os critérios de boas práticas indicam que a organização deve formalizar a designação de papéis e responsabilidades, assegurar o dimensionamento apropriado do quadro de pessoal, mapear funções críticas, capacitar periodicamente a equipe e supervisionar de forma estrita a atuação de prestadores de serviços externos².

Com base na análise das respostas aos itens 0101, 0105, 2701, 2702, 2703, 2704, 2705, 2706, 2708, 2801 e 2804 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrada capacidade institucional suficiente para sustentar a gestão de TIC e segurança da informação. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Cargos e carreiras específicas:** a ausência de cargos, funções ou perfis técnicos estruturados não demonstra aderência às boas práticas de atração e retenção de pessoal (COBIT 2019, APO07.01), podendo reduzir a responsabilização e a continuidade da gestão tecnológica.
- **Dependência externa:** a dependência externa relevante sem capacidade interna suficiente para coordenar e fiscalizar a TIC não demonstra aderência às boas

² Os critérios de capacidade institucional de TIC e segurança da informação concentram-se em pessoal adequado, competências, papéis, responsabilidades, retenção de conhecimento e supervisão de terceiros.

práticas de gestão de pessoal contratado e terceirizações (COBIT 2019, APO07.06, APO10.04 e DSS01.02), elevando riscos à governabilidade técnica e à continuidade das atividades do órgão.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Cargos, funções, perfis ou ocupações específicas de TIC e segurança da informação

Cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação ajudam a estruturar responsabilidades, atrair profissionais, definir requisitos mínimos e reduzir improvisação na alocação de pessoas.

O COBIT 2019, APO01.05, APO07.01 e APO07.02, orienta a definição de papéis e responsabilidades, a manutenção de pessoal adequado e a identificação de funções críticas de TI.

Da análise das respostas ao item 2708 e da documentação apresentada, verificou-se que a existência de cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem b) do item 2708, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que possui em sua estrutura cargos ou funções formalmente atribuídas à área de tecnologia da informação (E1);
- No subitem d) do item 2708, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que possui em sua estrutura cargos ou funções formalmente atribuídas à área de segurança da informação (E2).

A ausência de cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação pode reduzir a capacidade de atração, responsabilização e retenção de profissionais com perfil compatível com as necessidades da área.

Dependência externa e capacidade interna de coordenação e fiscalização

A utilização de terceiros ou de estrutura externa para execução de atividades de TIC não elimina a responsabilidade da organização pela coordenação, planejamento, aprovação técnica, fiscalização contratual e retenção de conhecimento.

O COBIT 2019, APO07.06, APO10.04 e DSS01.02, orienta o controle de pessoal contratado, a gestão de riscos de fornecedores e a supervisão de serviços terceirizados de TI, preservando responsabilização, medição, integração aos controles e retenção de conhecimento.

Da análise das respostas aos itens 0101 e 0105 e da documentação apresentada, verificou-se que a existência de capacidade interna para coordenar, planejar, fiscalizar e reter conhecimento quando a operação de TIC depende de terceiros ou de estrutura externa

não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- O quantitativo informado indicou predominância de profissionais terceirizados em relação aos profissionais internos de TIC (E3).

O estabelecimento de modelo operacional baseado predominantemente em recursos externos, sem capacidade interna suficiente de coordenação e supervisão, pode reduzir a governabilidade técnica, a retenção de conhecimento e a continuidade das operações de TIC.

Conclusão

As fragilidades identificadas na capacidade institucional de TIC e segurança da informação reduzem a segurança de que a organização disponha, conforme aplicável ao caso concreto, de pessoal, competências, papéis, perfis profissionais e mecanismos de supervisão suficientes para sustentar a gestão, a proteção, as contratações, a fiscalização e a continuidade dos serviços tecnológicos.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à adequação dos aspectos de capacidade institucional de TIC e segurança da informação efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que avalie a necessidade de instituir cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação e adote a solução compatível com as necessidades institucionais e a capacidade administrativa da organização;
- **Comunicação com Recomendação** para que avalie o modelo de operação de TIC e adote medidas proporcionais para assegurar capacidade interna suficiente de coordenação, planejamento, aprovação técnica, fiscalização contratual e retenção de conhecimento, especialmente quando a execução das atividades de TIC depender predominantemente de terceiros ou de estrutura externa.

Achado 5 – Gestão de serviços de TIC insuficiente para assegurar controle sobre serviços, ativos e incidentes

Crítérios

- COBIT 2019, APO09.02 - Catalogar serviços facilitados por TI: definir, manter e comunicar catálogo de serviços, incluindo serviços prestados, características, requisitos e níveis de serviço esperados;
- ITIL 4, prática de gerenciamento de nível de serviço: definir, acordar, monitorar, avaliar e reportar metas e níveis de serviço alinhados às necessidades das áreas usuárias;
- ITIL 4, prática de gerenciamento de ativos de TI: planejar e gerenciar o ciclo de vida dos ativos de TI, mantendo informações suficientes para apoiar controle, custo, risco, valor e tomada de decisão;
- ITIL 4, prática de gerenciamento de configuração de serviço: assegurar informações precisas e confiáveis sobre itens de configuração e seus relacionamentos com serviços, sistemas e infraestrutura;
- COBIT 2019, BAI10.01 - Estabelecer e manter um modelo de configuração: definir escopo, granularidade, atributos, relacionamentos e responsáveis pela base de configuração;

Evidências

- **E1:** A organização declarou “Sim” no subitem d) do item 2201, mas a evidência encaminhada foi considerada insuficiente para comprovar que são formalizados ANS contendo metas de nível de serviço acordadas com representantes das áreas de negócio clientes;
 - Justificativa da avaliação: Não foram apresentadas evidências da formalização de Acordos de Nível de Serviço (ANS) bilateralmente pactuados com representantes das áreas de negócio. Embora exista uma tabela de tempos de atendimento, esta configura um padrão interno unilateral da área de tecnologia, sem registros de negociação, atas de reunião ou termos de acordo com os clientes internos. A evidência é insuficiente por omitir a comprovação da pactuação formal requerida pelo critério;
- **E2:** Resposta negativa ao detalhamento a) do item 2203 do Questionário, para verificar se a organização mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles;

- **E3:** Resposta negativa ao detalhamento a) do item 2504 do Questionário, para verificar se a organização gerencia (inventaria e controla) os dispositivos conectados em sua rede;
- **E4:** Resposta negativa ao detalhamento c) do item 2203 do Questionário, para verificar se o processo de gestão de configuração e ativos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades).

Situação encontrada

A gestão de serviços de TIC organiza a forma como as soluções e o suporte tecnológico são entregues aos usuários e às áreas demandantes do órgão. Catálogo de serviços, Acordos de Nível de Serviço (ANS), inventário de ativos, gestão de configuração e gestão de incidentes constituem práticas básicas e integradas necessárias para assegurar a transparência operacional, continuidade do negócio, governabilidade financeira, controle de ativos e qualidade de suporte técnico.

Os critérios de boas práticas baseados na ITIL 4 e no COBIT 2019 indicam que a organização deve manter fonte unificada e consistente de informações sobre seu catálogo, estabelecer metas mensuráveis de atendimento, administrar ativamente o ciclo de vida dos ativos tecnológicos, rastrear os relacionamentos lógicos de configuração e registrar de forma sistemática e auditável todas as ocorrências operacionais e incidentes de segurança³.

Com base na análise das respostas aos itens 2201, 2203, 2204 e 2504 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrada adoção suficiente dessas práticas mínimas. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Níveis mínimos de serviço:** a ausência de parâmetros ou acompanhamento não demonstra aderência aos critérios de catálogo e gerenciamento de nível de serviço (ITIL 4 e COBIT 2019, APO09.02), dificultando a avaliação objetiva da qualidade e tempestividade dos serviços prestados.
- **Inventário de ativos de TIC:** a fragilidade ou inexistência de inventário não demonstra aderência à prática de gerenciamento de ativos de TI (ITIL 4), reduzindo o controle sobre recursos tecnológicos, licenciamentos de software, custos e riscos associados.
- **Gestão de configuração:** a ausência de mapeamento lógico não demonstra aderência à ITIL 4 e ao COBIT 2019 (BAI10.01), podendo prejudicar a confiabilidade das dependências operacionais entre infraestrutura, sistemas e serviços críticos.

³ As práticas de gestão de serviços de TIC adotadas como critério baseiam-se em ITIL 4 e COBIT 2019 e abrangem catálogo, níveis de serviço, ativos, configuração e incidentes.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Níveis de serviço e metas de atendimento

A definição de Acordos de Níveis de Serviço, metas mínimas ou parâmetros equivalentes permite pactuar expectativas, medir desempenho e avaliar a qualidade dos principais serviços de TIC.

A ITIL 4, na prática de gerenciamento de nível de serviço, orienta a definição, monitoramento, avaliação e reporte de metas e níveis de serviço alinhados às necessidades das áreas usuárias. O COBIT 2019, APO09.02, também relaciona o catálogo à comunicação de requisitos e níveis de serviço esperados.

Da análise das respostas ao item 2201 e da documentação apresentada, verificou-se que a definição ou o monitoramento de níveis mínimos de serviço, metas ou parâmetros equivalentes para os serviços de TIC relevantes não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem d) do item 2201, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que são formalizados ANS contendo metas de nível de serviço acordadas com representantes das áreas de negócio clientes (E1).

A ausência de níveis mínimos de serviço, metas estruturadas ou parâmetros equivalentes reduz a disponibilidade de bases objetivas para monitorar e avaliar a qualidade, o tempo de resposta e a eficiência dos serviços prestados.

Inventário de ativos de TIC

O inventário de ativos de TIC deve permitir conhecer e controlar equipamentos, servidores, sistemas, *softwares*, licenças, serviços em nuvem, responsáveis e componentes de infraestrutura.

A ITIL 4, na prática de gerenciamento de ativos de TI, orienta o gerenciamento do ciclo de vida dos ativos, mantendo informações suficientes para apoiar controle, custo, risco, valor e tomada de decisão.

Da análise das respostas aos itens 2203 e 2504 e da documentação apresentada, verificou-se que a existência de inventário de ativos de TIC atualizado e abrangente não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2203, não houve declaração afirmativa quanto à prática avaliada: mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles (E2);

- No subitem a) do item 2504, não houve declaração afirmativa quanto à prática avaliada: gerencia (inventaria e controla) os dispositivos conectados em sua rede (E3).

A ausência de inventário atualizado e abrangente de ativos de TIC reduz a segurança quanto ao controle sobre equipamentos, sistemas, softwares, licenças, serviços em nuvem e componentes de infraestrutura, elevando riscos relacionados a custos, conformidade, segurança da informação e planejamento de capacidade.

Gestão de configuração

A gestão de configuração deve manter informações precisas e confiáveis sobre itens de configuração relevantes, seus atributos, responsáveis e relacionamentos com ativos, sistemas, infraestrutura e serviços.

A ITIL 4, na prática de gerenciamento de configuração de serviço, orienta assegurar informações confiáveis sobre itens de configuração e seus relacionamentos. O COBIT 2019, BAI10.01, exige a definição de escopo, granularidade, atributos, relacionamentos e responsáveis pela base de configuração.

Da análise das respostas ao item 2203 e da documentação apresentada, verificou-se que a existência de processo mínimo de gestão de configuração com registro de itens relevantes, atributos, responsáveis e relacionamentos entre ativos, sistemas, infraestrutura e serviços não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2203, não houve declaração afirmativa quanto à prática avaliada: mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles (E2);
- No subitem c) do item 2203, não houve declaração afirmativa quanto à prática avaliada: o processo de gestão de configuração e ativos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades) (E4).

A ausência de registros suficientes de configuração dificulta o mapeamento lógico das dependências entre servidores, bancos de dados, aplicações e serviços finalísticos, podendo reduzir a capacidade de análise de riscos em mudanças operacionais e de tratamento de falhas sistêmicas.

Conclusão

As fragilidades identificadas na gestão de serviços de TIC reduzem a segurança de que a organização disponha, conforme aplicável ao caso concreto, de práticas suficientes

para assegurar eficiência, continuidade, rastreabilidade, qualidade dos serviços prestados e controle sobre ativos, configurações e incidentes.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à estruturação e à adequação das práticas de gestão de serviços de TIC efetivamente apontadas neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que defina, pactue e monitore níveis mínimos de serviço ou metas de atendimento para os serviços de TIC mais relevantes, estabelecendo indicadores, responsáveis, periodicidade de medição e forma de comunicação dos resultados;
- **Comunicação com Recomendação** para que estabeleça e mantenha atualizado inventário de ativos de TIC, atentando-se, minimamente, em registrar equipamentos, servidores, sistemas, softwares, licenças, serviços em nuvem, componentes de infraestrutura, responsáveis e informações necessárias ao controle do ciclo de vida dos ativos;
- **Comunicação com Recomendação** para que formalize e execute processo de gestão de configuração, atentando-se, minimamente, em manter base, ferramenta ou registro equivalente com os itens de configuração relevantes, seus responsáveis e os relacionamentos entre ativos, sistemas, infraestrutura e serviços, com atualização periódica e uso das informações no planejamento e acompanhamento de mudanças.

Achado 6 – Fragilidades na governança técnica da fase preparatória das contratações de TIC

CrITÉRIOS

- Art. 11, parágrafo único, da Lei 14.133/2021: responsabilidade da alta administração pela governança das contratações, com processos, estruturas, gestão de riscos e controles internos;
- Art. 18, caput e §1º, incisos I, IV, V, VIII, IX, X e XIII, da Lei 14.133/2021: fase preparatória caracterizada pelo planejamento, compatibilização com o plano de contratações anual e elementos mínimos do estudo técnico preliminar;
- COBIT 2019, BAI02.04 - Obter aprovação dos requisitos da solução: obter aprovação formal dos requisitos funcionais, técnicos, de segurança e de conformidade antes de prosseguir com a solução;
- COBIT 2019, APO01.05 - Estabelecer papéis e responsabilidades: definir e comunicar papéis e responsabilidades relacionados à informação e à tecnologia;
- Instrução Normativa SGD/ME nº 94, de 23 de dezembro de 2022, art. 1º, § 1º: como referência de boa prática, a aplicação de ritos formais de contratação de TIC pode ser facultada para contratações diretas por dispensa em razão do valor (inciso II do art. 75 da Lei nº 14.133/2021), indicando a possibilidade de fluxos simplificados para aquisições de baixa complexidade ou valor.

Evidências

- **E1:** A organização declarou “Sim” no subitem a) do item 2804, mas a evidência encaminhada foi considerada insuficiente para comprovar que as contratações de soluções de TI, independentemente de qual seja a área demandante, são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI;
 - Justificativa da avaliação: A evidência apresentada é insuficiente para demonstrar o cumprimento do requisito de análise prévia e aprovação técnica das contratações de TI. O arquivo disponibilizado consiste, exclusivamente, na captura de tela de uma ferramenta de compartilhamento de arquivos, sem qualquer teor normativo ou registro administrativo que comprove o fluxo de governança exigido. A avaliação realizada constata a ausência de elementos que comprovem a existência ou a aplicação da rotina de aprovação técnica pela área de gestão de TI. Faz-se necessária a apresentação de norma

interna que estabeleça o fluxo obrigatório e de evidências de casos concretos que demonstrem a efetiva tramitação de contratações sob tal diretriz;

- **E2:** Resposta negativa ao detalhamento c) do item 2102 do Questionário, para verificar se o plano de TI fundamenta a proposta orçamentária da área de TI e o plano de contratações.

Situação encontrada

As contratações de TIC devem observar governança técnica, planejamento prévio proporcional à complexidade do objeto, participação da área de tecnologia quando cabível e critérios objetivos para recebimento e mensuração de resultados. A complexidade dos ativos de tecnologia, as exigências de conformidade legal, incluindo LGPD quando aplicável, e a dependência das atividades finalísticas em relação aos serviços de TIC demandam controles compatíveis com a relevância, o risco e o valor da contratação.

Os critérios previstos na Lei 14.133/2021, na Lei 13.709/2018 (LGPD) e nos objetivos do COBIT 2019 disciplinam que a alta administração responde pela governança das contratações, que a fase preparatória deve ser instruída com planejamento compatível com o objeto e que os Termos de Referência (TR), projetos básicos, contratos ou instrumentos equivalentes devem conter requisitos, modelos de execução, critérios de medição e parâmetros de acompanhamento proporcionais à natureza da contratação⁴.

Com base na análise das respostas aos itens 2801, 2804, 2102 e 2802 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrado atendimento suficiente das contratações de TIC da organização a essas diretrizes. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Aprovação técnica de TIC:** a falta de avaliação prévia pela área técnica, quando necessária, contraria a governança institucional (COBIT 2019, BAI02.04 e APO01.05), favorecendo aquisições de soluções desalinhadas do ambiente tecnológico existente.
- **Alinhamento ao planejamento:** a ausência de alinhamento demonstrado ao planejamento de TIC, ao plano de contratações ou à proposta orçamentária não demonstra aderência à Lei 14.133/2021 (arts. 11 e 18), podendo resultar em aquisições reativas ou sem lastro orçamentário adequado.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

⁴ Os critérios de contratações de TIC combinam requisitos legais da Lei 14.133/2021, requisitos de segurança e proteção de dados da LGPD e boas práticas do COBIT 2019 sobre requisitos, papéis, procedimentos, contratos e desempenho de fornecedores.

Análise prévia e aprovação técnica da área de TIC

As contratações de TIC devem ser submetidas à análise prévia e aprovação técnica da área de TIC, inclusive quando demandadas por outras áreas da organização. Essa análise é necessária para verificar compatibilidade técnica, segurança, integração com o ambiente existente, riscos e aderência a padrões institucionais.

O COBIT 2019, BAI02.04, orienta a obtenção de aprovação formal dos requisitos funcionais, técnicos, de segurança e de conformidade antes de prosseguir com a solução. O COBIT 2019, APO01.05, reforça a definição de papéis e responsabilidades relacionados à informação e à tecnologia. De forma complementar, o art. 1º, § 1º, da Instrução Normativa SGD/ME nº 94/2022, adotado como referência de boa prática, aponta a possibilidade de facultar a aplicação de ritos formais para contratações diretas por dispensa em razão do valor (inciso II do art. 75 da Lei nº 14.133/2021), indicando que os controles e pareceres podem ser proporcionais à relevância estratégica, complexidade e valor da aquisição.

Da análise das respostas ao item 2804 e da documentação apresentada, verificou-se que a submissão das contratações de TIC à análise prévia ou aprovação técnica da área de TIC, inclusive quando demandadas por outras áreas, não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2804, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que as contratações de soluções de TI, independentemente de qual seja a área demandante, são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI (E1).

A ausência de análise prévia ou aprovação técnica da área de TIC reduz a segurança de que as soluções contratadas sejam compatíveis com o ambiente tecnológico existente, com os requisitos institucionais e com os controles mínimos de segurança da informação, observada a proporcionalidade em relação à complexidade, ao risco e ao valor da contratação.

Alinhamento ao planejamento, plano de contratações e proposta orçamentária

As contratações de TIC devem estar vinculadas ao planejamento de TIC, ao plano de contratações e à proposta orçamentária. Essa vinculação demonstra que a contratação decorre de prioridade definida, possui respaldo orçamentário e contribui para objetivos institucionais.

O art. 18 da Lei 14.133/2021 prevê a compatibilização da contratação com o plano de contratações anual e o planejamento da Administração. O art. 11 também reforça a responsabilidade da alta administração pela governança das contratações.

Da análise das respostas aos itens 2102, 2802 e 2804 e da documentação apresentada, verificou-se que o alinhamento das contratações de TIC ao planejamento de

TIC, ao plano de contratações ou à proposta orçamentária não se mostrou suficientemente demonstrado, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 2102, não houve declaração afirmativa quanto à prática avaliada: o plano de TI fundamenta a proposta orçamentária da área de TI e o plano de contratações (E2).

A ausência de alinhamento das contratações de TIC ao planejamento de TIC, ao plano de contratações ou à proposta orçamentária eleva o risco de fragmentação de despesas, contratações reativas ou insuficientemente priorizadas e uso pouco eficiente dos recursos orçamentários.

Conclusão

As fragilidades evidenciadas na fase preparatória das contratações de TIC reduzem a segurança de que a organização disponha de controles suficientes para assegurar, conforme aplicável ao caso concreto, processo formal de contratação, participação técnica da área de TIC, alinhamento ao planejamento e adequada instrução dos processos. Essas fragilidades elevam o risco de contratações insuficientemente fundamentadas, pouco rastreáveis ou desalinhadas às necessidades institucionais, à complexidade e aos riscos das soluções de TIC pretendidas.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à estruturação e à adequação dos aspectos da fase preparatória das contratações de TIC efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que estabeleça a submissão das contratações de TIC à análise prévia da área de TIC, inclusive quando demandadas por outras áreas, de modo a verificar a compatibilidade da solução com os padrões tecnológicos, os requisitos institucionais, a segurança da informação e a arquitetura existente, admitindo fluxos simplificados para contratações de baixa complexidade ou baixo valor, desde que preservada análise técnica mínima compatível com o risco da contratação;
- **Comunicação com Recomendação** para que integre as contratações de TIC ao planejamento de TIC, ao plano de contratações e à proposta orçamentária, atentando-se, minimamente, em registrar a necessidade atendida, a prioridade, a disponibilidade de recursos e a justificativa das situações excepcionais.

4. Plano de ação

Para facilitar o atendimento das propostas constantes da Seção 3, a Equipe de Auditoria elaborou modelo preliminar de plano de ação contendo os encaminhamentos propostos à organização. O quadro não antecipa decisão final desta Corte de Contas e poderá ser revisto após a análise dos comentários do gestor.

Cumpre registrar que, em conformidade com o art. 4º, incisos I e II, da Deliberação TCE-RJ nº 346/2024, cabe à unidade jurisdicionada avaliar a conveniência e a oportunidade de implementar as recomendações. Ressalta-se, contudo, que a eventual decisão pela não aderência deve ser motivada: o gestor deve apresentar justificativa formal que demonstre, à luz das circunstâncias do caso concreto, as razões da decisão e, quando cabível, as medidas alternativas adotadas para tratar a situação que ensejou a recomendação.

Tabela 8 - Plano de ação contendo os encaminhamentos preliminarmente propostos

Achado	Medida proposta	Avaliação de		
		Viabilidade	Quem?	Quando?
3	institua processo formal de planejamento de TIC, compatível com o porte e a maturidade da organização, atentando-se, minimamente, em definir etapas, responsáveis, participação das áreas demandantes e critérios de priorização das necessidades e iniciativas de TIC			
3	integre o plano de TIC à proposta orçamentária, ao plano de contratações e às contratações de TIC, atentando-se, minimamente, em priorizar as demandas conforme sua relevância, seus riscos e a capacidade de execução da organização			
4	avaleie a necessidade de instituir cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação e adote a solução compatível com as necessidades institucionais e a capacidade administrativa da organização			
4	avaleie o modelo de operação de TIC e adote medidas proporcionais para assegurar capacidade interna suficiente de coordenação, planejamento, aprovação técnica, fiscalização contratual e retenção de conhecimento, especialmente quando a execução das atividades de TIC depender predominantemente de terceiros ou de estrutura externa			
5	defina, pactue e monitore níveis mínimos de serviço ou metas de atendimento para os serviços de TIC mais relevantes, estabelecendo indicadores, responsáveis, periodicidade de medição e forma de comunicação dos resultados			

Achado	Medida proposta	Avaliação de		
		Viabilidade	Quem?	Quando?
5	estabeleça e mantenha atualizado inventário de ativos de TIC, atentando-se, minimamente, em registrar equipamentos, servidores, sistemas, softwares, licenças, serviços em nuvem, componentes de infraestrutura, responsáveis e informações necessárias ao controle do ciclo de vida dos ativos			
5	formalize e execute processo de gestão de configuração, atentando-se, minimamente, em manter base, ferramenta ou registro equivalente com os itens de configuração relevantes, seus responsáveis e os relacionamentos entre ativos, sistemas, infraestrutura e serviços, com atualização periódica e uso das informações no planejamento e acompanhamento de mudanças			
6	estabeleça a submissão das contratações de TIC à análise prévia da área de TIC, inclusive quando demandadas por outras áreas, de modo a verificar a compatibilidade da solução com os padrões tecnológicos, os requisitos institucionais, a segurança da informação e a arquitetura existente, admitindo fluxos simplificados para contratações de baixa complexidade ou baixo valor, desde que preservada análise técnica mínima compatível com o risco da contratação			
6	integre as contratações de TIC ao planejamento de TIC, ao plano de contratações e à proposta orçamentária, atentando-se, minimamente, em registrar a necessidade atendida, a prioridade, a disponibilidade de recursos e a justificativa das situações excepcionais			

(Fonte: elaboração própria)

Apêndice A. Comparabilidade com o ciclo anterior (iGovTI 2023 vs. iGovTI 2026)

A estrutura de 2026 preservou a escala de 0 a 1, as categorias de resposta e as quatro faixas de maturidade empregadas em 2023, mas alterou de forma relevante a composição dos agregados e seus pesos. As principais diferenças estão sintetizadas na Tabela 9.

Tabela 9 - Principais diferenças entre as estruturas do iGovTI 2023 e do iGovTI 2026

Aspecto	iGovTI 2023	iGovTI 2026	Implicação analítica
Composição do índice final	Governança de TIC e Gestão de TIC com pesos iguais de 0,50.	Governança de TIC com peso 0,4777 e Gestão de TIC com peso 0,5223.	A gestão passou a ter participação ligeiramente superior no índice final.
Governança de TIC	Agregação hierárquica de ModeloTI, MonitorAvaliaTI e ResultadoTI.	Agregação direta de quatro práticas relativas ao modelo de gestão, monitoramento, auditoria interna e simplificação de serviços públicos.	O componente tornou-se mais direto e incorporou práticas com escopo distinto da estrutura anterior.
Gestão de TIC	Agregação de Planejamento de TIC, Pessoas e Processos de TIC; este último reunia serviços, níveis de serviço, riscos, segurança, software, projetos e contratos.	Agregação direta das seis dimensões de Gestão de TIC descritas neste relatório.	O índice passou a evidenciar separadamente seis capacidades operacionais e de segurança.
Pessoas e contratações	Pessoas e contratações de TIC integravam o cálculo da Gestão de TIC.	Não integram a árvore de cálculo do iGovTI 2026, embora continuem relevantes para o diagnóstico e para a auditoria.	Mudanças nessas matérias não explicam diretamente a variação do índice de 2026.
Serviços, software e projetos	Serviços e níveis de serviço eram agregados distintos; software e projetos integravam Processos de TIC.	Serviços foram consolidados na dimensão Gestão de Serviços de TIC; software e projetos foram reunidos na dimensão Gestão de Soluções de TIC.	A leitura deve considerar a nova delimitação conceitual dos componentes.

(Fonte: elaboração própria)

Em razão dessas alterações, a diferença entre os valores nominais de 2023 e 2026 não deve ser interpretada automaticamente como evolução ou retrocesso institucional. Uma análise temporal válida exige a harmonização das questões e dos agregados comparáveis, além da consideração de mudanças de escopo, pesos, respondentes e qualidade das evidências.

Para viabilizar a análise longitudinal, foram elaboradas estruturas ajustadas comparáveis para 2023 e 2026, com a manutenção apenas das práticas passíveis de correspondência entre os instrumentos e a aplicação de uma estrutura comum de agregação. Após a normalização das siglas e a validação das correspondências institucionais, foram identificadas 69 organizações presentes nos dois ciclos, equivalentes a 60,5% das organizações com respostas completas em 2026. A comparação individual foi apresentada somente para esse conjunto pareado.

Os resultados ajustados comparáveis têm finalidade exclusivamente analítica. Eles não substituem os índices oficiais de cada ciclo, não eliminam integralmente os efeitos de alterações de respondentes ou de contexto institucional e não constituem, isoladamente, evidência de conformidade ou de inconformidade.

Apêndice B. Ajustes nas respostas declaradas

A Equipe de Auditoria, em busca da melhor representação do cenário atual de governança e gestão de TIC, ajustou resposta(s) declarada(s) pela organização **TJRJ** ao questionário iGovTI 2026.

Para tanto, foram utilizadas as justificativas e evidências fornecidas pelo jurisdicionado quando do envio das respostas ao questionário. Ressalta-se que a verificação dessa documentação foi realizada nos termos dos procedimentos definidos para a fiscalização, de modo que nem todas as evidências encaminhadas foram, necessariamente, objeto de análise exaustiva pela Equipe de Auditoria.

Seguem as alterações realizadas após a avaliação das respostas e da amostra de evidências, bem como as justificativas apresentadas pela Equipe:

Tabela 10 - Relação de respostas ajustadas pela Equipe após validação

Questão	Resposta original	Resposta ajustada	Justificativa
q2201ext[D]	Sim	Não	Não foram apresentadas evidências da formalização de Acordos de Nível de Serviço (ANS) bilateralmente pactuados com representantes das áreas de negócio. Embora exista uma tabela de tempos de atendimento, esta configura um padrão interno unilateral da área de tecnologia, sem registros de negociação, atas de reunião ou termos de acordo com os clientes internos. A evidência é insuficiente por omitir a comprovação da pactuação formal requerida pelo critério.
q2501ext[E]	Sim	Não	O processo de gestão não contempla ações mitigatórias específicas para eventos catastróficos. Embora o Ato Normativo nº 10/2019 trate de riscos e manutenção geral (arts. 10 e 13), não apresenta diretrizes ou planos de contingência e continuidade voltados especificamente à indisponibilidade de ativos críticos por desastre. A evidência é insuficiente por omitir estratégias para cenários de eventos catastróficos. É necessária a apresentação de plano de continuidade ou documento equivalente que aborde tais eventos.
q2504ext[D]	Sim	Não	A Equipe de Auditoria avalia que, embora existam ações de remediação isoladas, não há evidências da aplicação de padrões de configuração segura (hardening) em ambiente produtivo. Falta documentação ou registros que comprovem a existência de baselines de segurança aplicados aos ativos críticos. A evidência é insuficiente por tratar apenas de recomendações pontuais de pentest, sem comprovar conformidade contínua.

Questão	Resposta original	Resposta ajustada	Justificativa
q2504ext[E]	Sim	Não	A Equipe de Auditoria avalia que a organização mantém o armazenamento de logs, mas não apresenta evidências da análise e monitoramento contínuos. Não foram disponibilizados relatórios de revisão, dashboards ou evidências de tratamento de alertas que comprovem a análise ativa dos dados coletados. A evidência é insuficiente por restringir-se ao armazenamento.
q2504ext[F]	Sim	Não	A Equipe de Auditoria avalia que não há evidências apresentadas que comprovem controles compensatórios específicos para privilégios administrativos. Não foram fornecidos registros de gestão de acessos privilegiados, segregação de funções ou monitoramento do uso de contas administrativas. A evidência apresentada é insuficiente por ausência total de comprovação.
q2504ext[H]	Sim	Não	A Equipe de Auditoria avalia que não foram apresentadas evidências documentais ou técnicas que comprovem o controle de portas e protocolos de rede. Não constam regras de firewall ou políticas de rede que demonstrem a implementação de restrições ou segmentação. A evidência é insuficiente por ausência de documentação de configuração de rede.
q2504ext[I]	Sim	Não	A Equipe de Auditoria avalia que não há evidência de defesa de perímetro formalmente implementada. O relatório de teste de intrusão menciona a ausência de mitigação em serviços expostos, e não há comprovação da existência de firewalls de borda, IDS/IPS ou mecanismos similares operando no perímetro. A evidência é insuficiente por falta de comprovação de controles perimetrais.
q2708[A]	Sim	Não	A avaliação realizada indica que a evidência é insuficiente. O arquivo enviado apresenta apenas a interface de configuração de um serviço de compartilhamento de arquivos, sem conter o ato normativo, edital ou documento estrutural que comprove a existência de cargo efetivo de tecnologia da informação. A evidência não permite verificar a existência ou previsão de tais cargos no quadro de pessoal do auditado. A lacuna consiste na ausência de documento comprobatório formal.
q2708[B]	Sim	Não	A avaliação realizada conclui pela insuficiência da evidência apresentada. O material consiste exclusivamente em captura de tela de interface de compartilhamento de arquivos, carecendo de qualquer organograma, ato de designação ou normativo interno que vincule formalmente funções à área de tecnologia da informação. A evidência é ineficaz para demonstrar a estrutura organizacional pretendida. A lacuna principal é a inexistência de documento oficial que formalize tais atribuições.

Questão	Resposta original	Resposta ajustada	Justificativa
q2708[C]	Sim	Não	A avaliação realizada indica a insuficiência da prova documental. A evidência fornecida restringe-se a uma interface digital de compartilhamento, sem apresentar lei, edital, plano de cargos ou documento congênere que demonstre a criação ou previsão de cargos efetivos de segurança da informação. A ausência de conteúdo substantivo impede a verificação do item. A lacuna reside na falta de documento formal que sustente a existência do referido cargo.
q2708[D]	Sim	Não	A avaliação realizada conclui pela insuficiência da evidência. O arquivo enviado não contém elementos comprobatórios como organogramas, normas ou atos de designação que formalizem atribuições para a área de segurança da informação, limitando-se a uma imagem de interface de sistema. A evidência não permite confirmar a existência da estrutura organizacional necessária. A lacuna consiste na falta de documentação oficial que detalhe a função ou cargo em segurança da informação.
q2804[A]	Sim	Não	A evidência apresentada é insuficiente para demonstrar o cumprimento do requisito de análise prévia e aprovação técnica das contratações de TI. O arquivo disponibilizado consiste, exclusivamente, na captura de tela de uma ferramenta de compartilhamento de arquivos, sem qualquer teor normativo ou registro administrativo que comprove o fluxo de governança exigido. A avaliação realizada constata a ausência de elementos que comprovem a existência ou a aplicação da rotina de aprovação técnica pela área de gestão de TI. Faz-se necessária a apresentação de norma interna que estabeleça o fluxo obrigatório e de evidências de casos concretos que demonstrem a efetiva tramitação de contratações sob tal diretriz.

(Fonte: elaboração própria)